

Cybersecurity Boot Camp

Attacking and Defending

Lesson 1.2



Learning Objectives

By the end of today's class, you will be able to:

- 1 Understand the security mindset.
- 2 List different types of user, web, server, and database cybersecurity attacks.
- 3 Identify risk mitigation plan frameworks for these attacks.



Let's recap



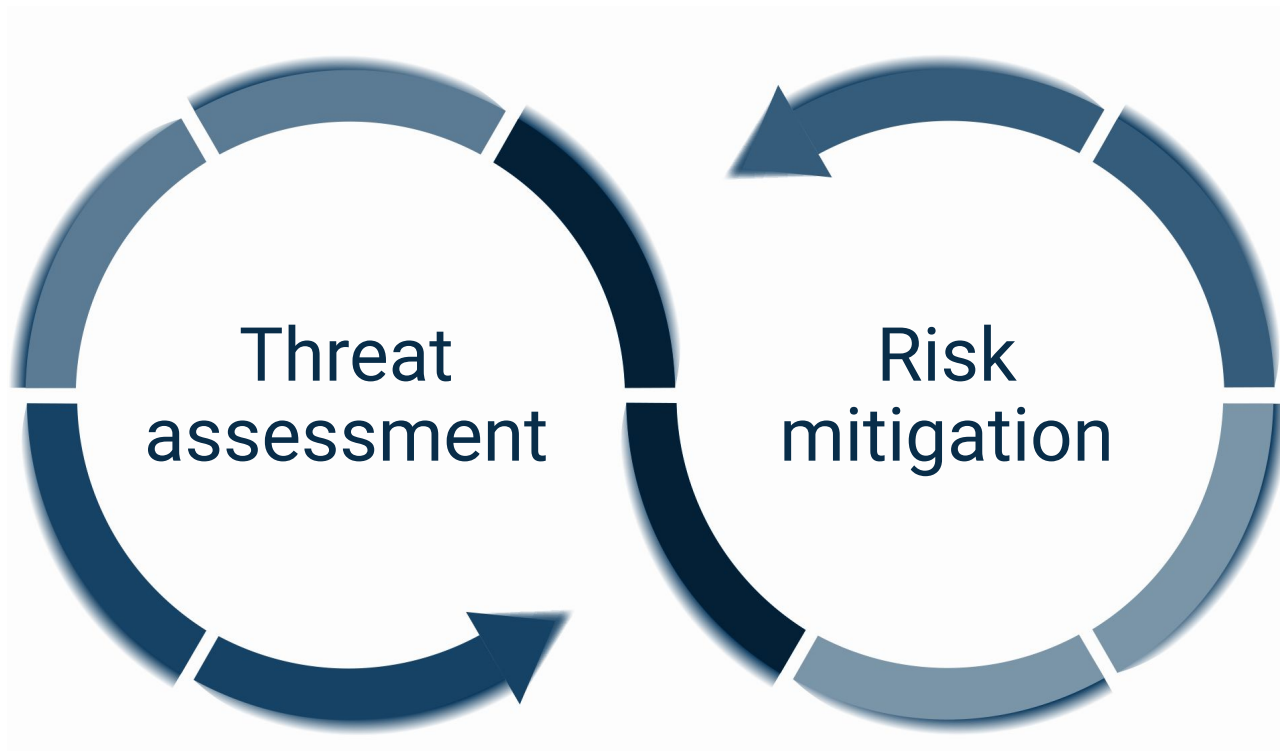
Recap

The two concepts cybersecurity are centered on are:



Recap

The two concepts cybersecurity are centered on are:



Recap

The central definitions of threat assessment and risk mitigation are:

Threat Assessment

The structured process of identifying the threats posed to a group or system

Risk Mitigation

The systematic reduction of the impact or likely occurrence of a negative event



Recap:

In other words...

Threat assessment:

What could happen?

Risk mitigation:

How do we handle it?





Why do we use the term “**mitigation**”
and not “**eradication**”?





Mitigation, not eradication:

We cannot eradicate **all** risks.

Cybersecurity is an ever-evolving landscape.





Welcome

Today's Class

We will continue with assessing threats and mitigating risks by evaluating specific attacks and vulnerabilities associated with:



Users



Web applications



Servers



Databases

Think like **offensive**
and **defensive**
cybersecurity
professionals





Activity:

Security Task #1

Suppose you have found an unattended iPhone left at a table in a restaurant.

The iPhone is not locked with a password, and every feature and app is accessible.



As a class, **let's identify as many exploits as possible** that could result from a stolen cell phone.

Hint: Be creative! Think like an attacker.

- What is the worst possible damage that could happen?
- Think about real damage.
- Think beyond the value of the phone itself.

Suggested Time:
20 minutes



Time's up!
Let's review



Quick Review

Oh look, a phone!

Potential Adverse Events

1. The phone is wiped and resold.
2. Phone memory is harvested and photos and sensitive material are used for blackmail.
3. Credentials for email and social media accounts are used to extract financial gain.
4. Installed applications are used to make purchases.
5. Malware software is directly installed to track future activity.
6. Phone contacts are socially engineered to provide money.
7. The phone is used to conduct illegal activity.
8. The owner's identity is stolen.



Security Task #2

Attacking the Wall

Congratulations! You have been hired by Bitcoin Dating Exchange.

While their founding team is brilliant, like many startups, **they don't know the first thing about security.**

They just handed you a lot of money to solve their **most critical problem.**

Attackers **are routinely logging in** as users and administrators and gaining access to company data and financial assets.

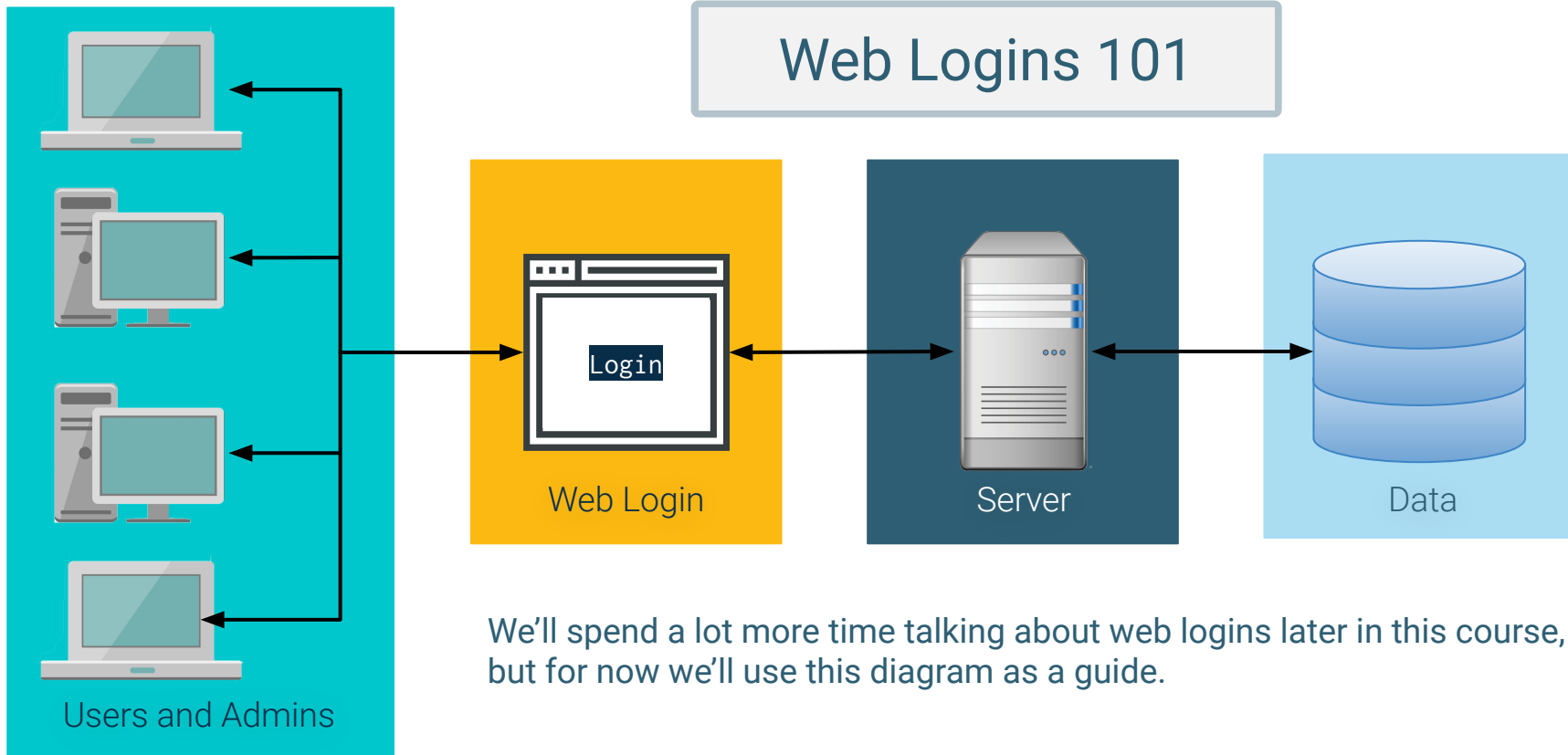




Activity: Security Task #2

Attacking the Wall

Web Logins 101





Activity:

Attacking the Wall

In groups, develop a list of 15 ways that a malicious actor could penetrate the system and log in as a user or administrator.

- With each method, describe the following:
 - Who (or what) is the initial target?
 - How would the actor implement the attack?

Suggested Time:
20 Minutes



Time's up!
Let's review

Activity: Security Task #2

Defining Attack Strategies



Brute force attack



Phishing



Keylogging



Session hijacking



Person-in-the-middle attack

Activity: Security Task #2

Defining Attack Strategies Cont.



Credential stuffing



SQL injection



Cross-site scripting



Exploiting outdated software



Social engineering

Defining Attack Strategies

Attack option #1: Brute force attack

An attacker can use a brute force attack to continuously attempt username and password combinations.



Username: bob@bbb.com Password: Love
Username: bob@bbb.com Password: Love123
Username: bob@bbb.com Password: Love123!
Username: bob@bbb.com Password: L@ve123

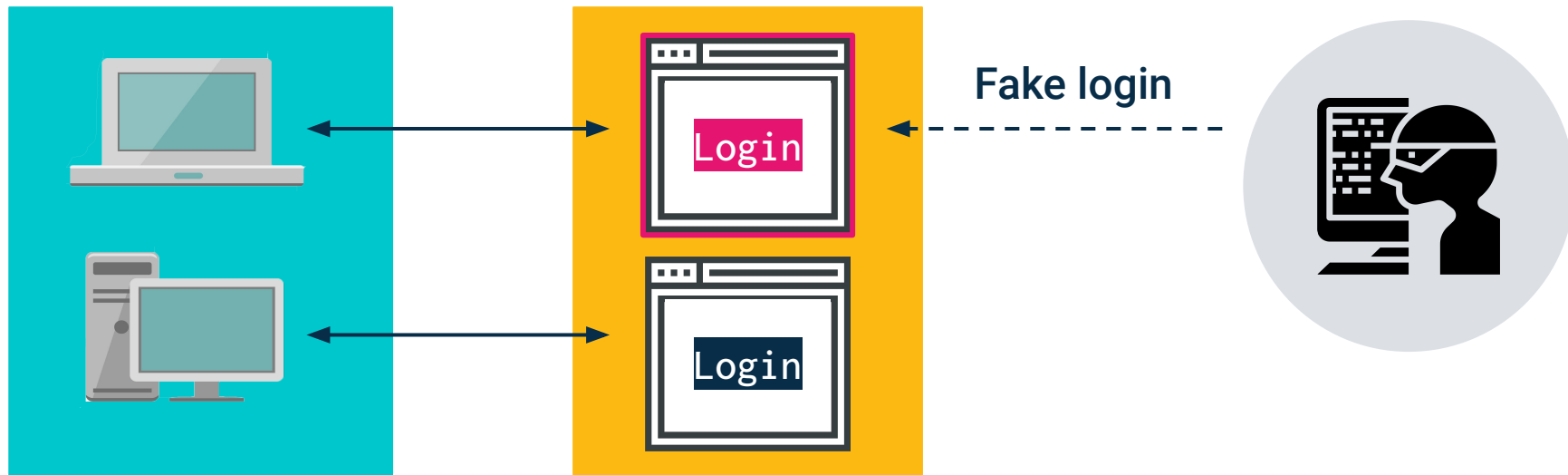


Password dictionary

Defining Attack Strategies

Attack option #2: Phishing

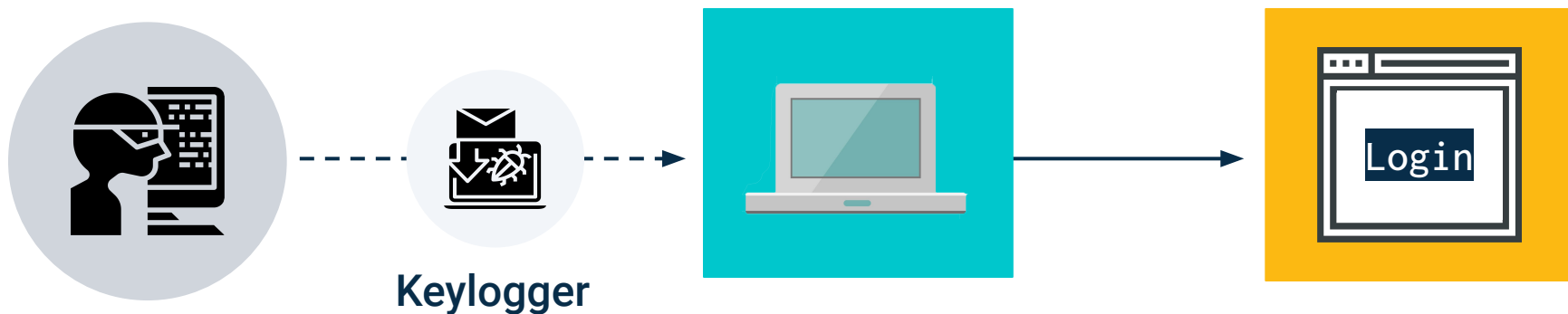
An attacker can attempt a phishing attack, where users are redirected to fake login pages that capture user credentials.



Defining Attack Strategies

Attack option #3: Keylogging

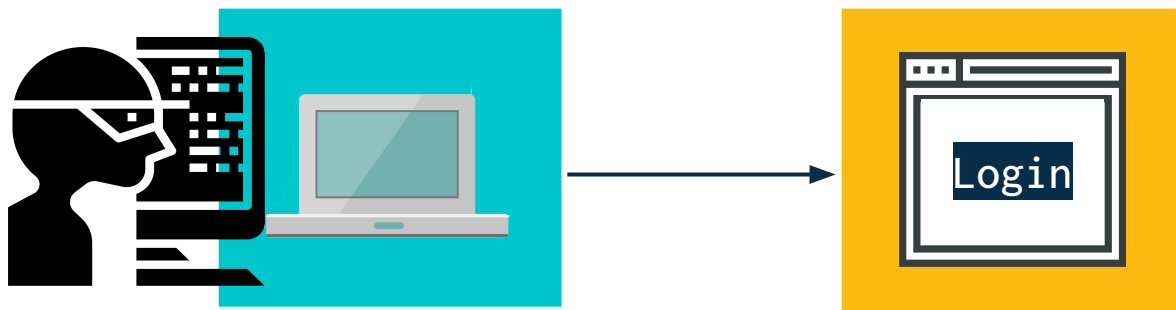
An attacker can deploy malware such as keyloggers to capture daily user activity.



Defining Attack Strategies

Attack option #4: Stolen hardware

An attacker can simply exploit a valid computer session to gain unauthorized access to information or services.

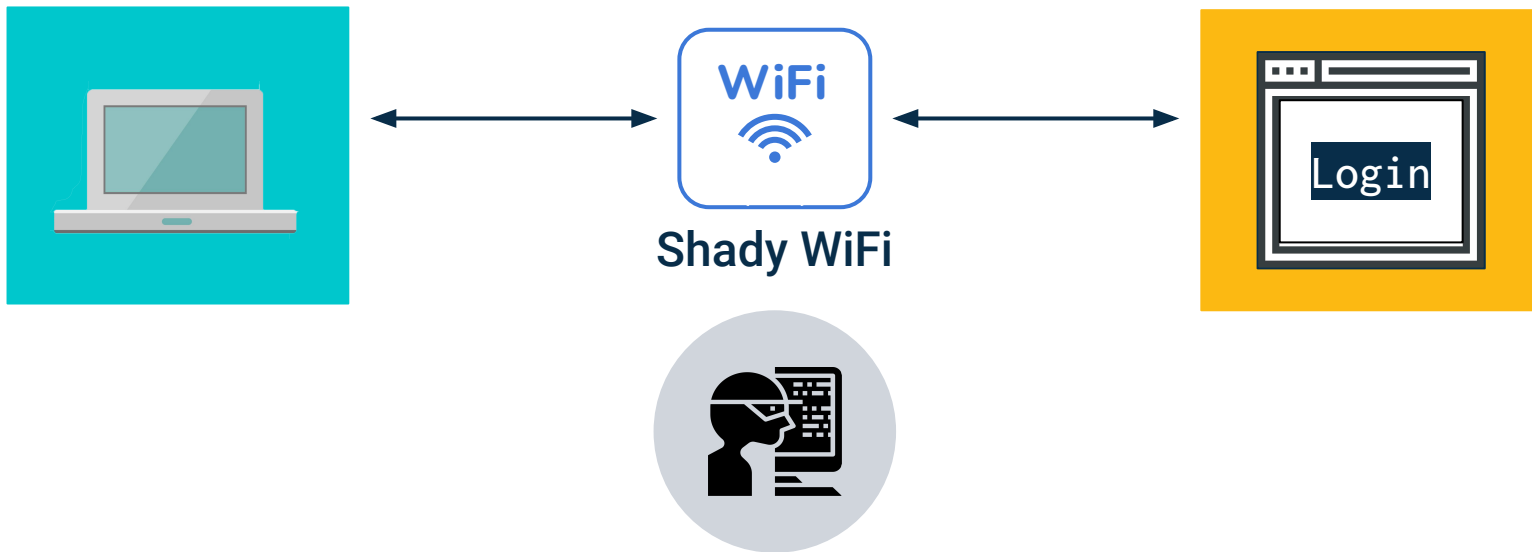


Computer left open

Defining Attack Strategies

Attack option #5: Person-in-the-middle attack

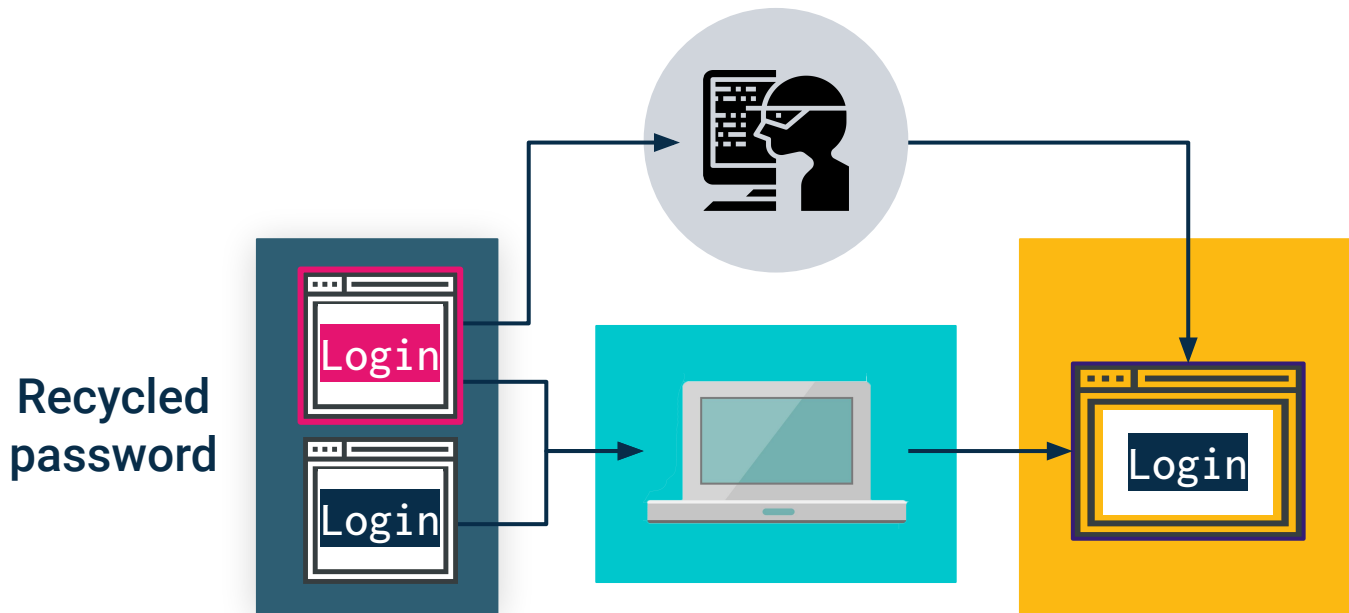
An attacker can create a person-in-the-middle attack by providing a free WiFi hotspot to capture user credentials.



Defining Attack Strategies

Attack option #6: Credential stuffing

An attacker can find and steal users' login and password information from other websites to gain unauthorized access to a system.



Defining Attack Strategies

Attack option #7: SQL injection

An attacker can use a code-injection attack to inject malicious code directly into username or password fields.



Username:

```
uName = getRequestString("username");  
uPass = getRequestString("userpassword");  
  
sql = 'SELECT * FROM Users WHERE Name =' +  
      uName + ' " AND Pass =' + uPass + ' "'
```

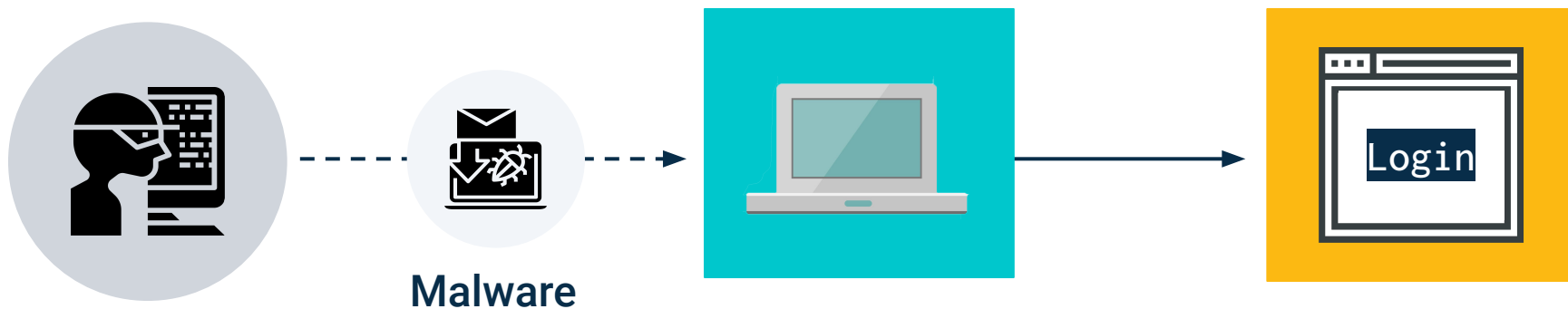


Password dictionary

Defining Attack Strategies

Attack option #8: Cross-site scripting (XSS)

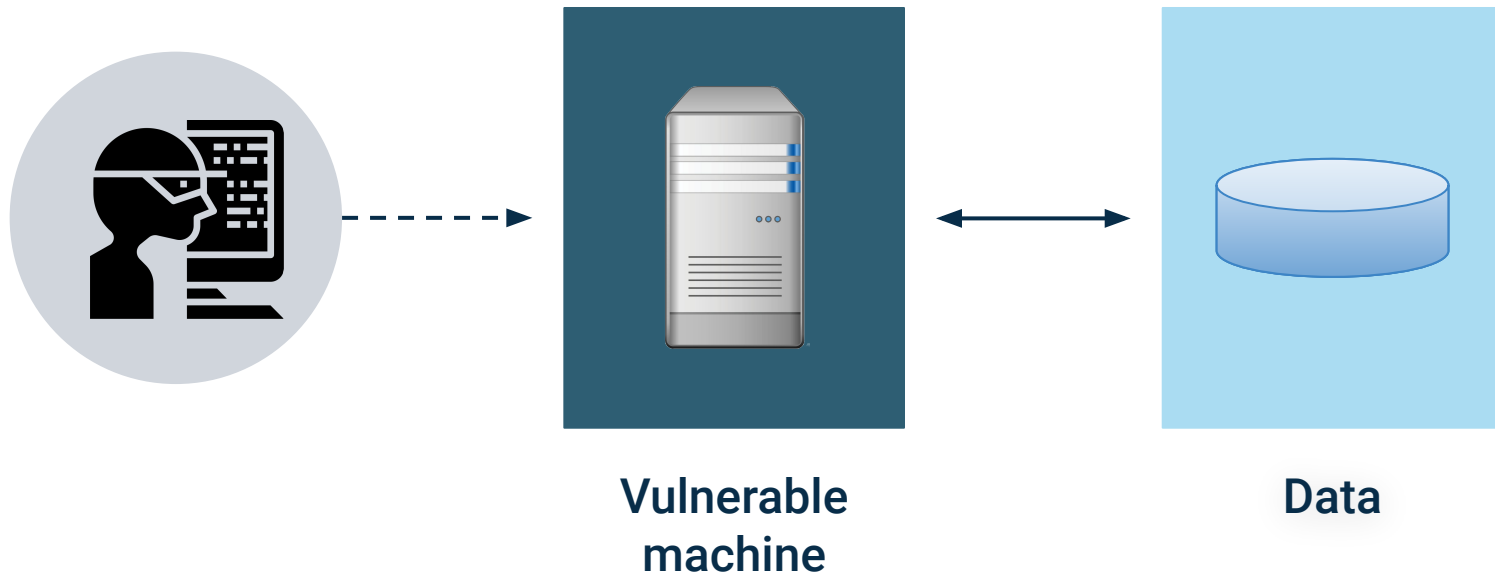
An attacker can inject malicious scripts into web pages viewed by other users and use these as a backdoor into their systems.



Defining Attack Strategies

Attack option #9: Exploiting outdated software

Attackers can use known vulnerabilities in outdated software to breach security.



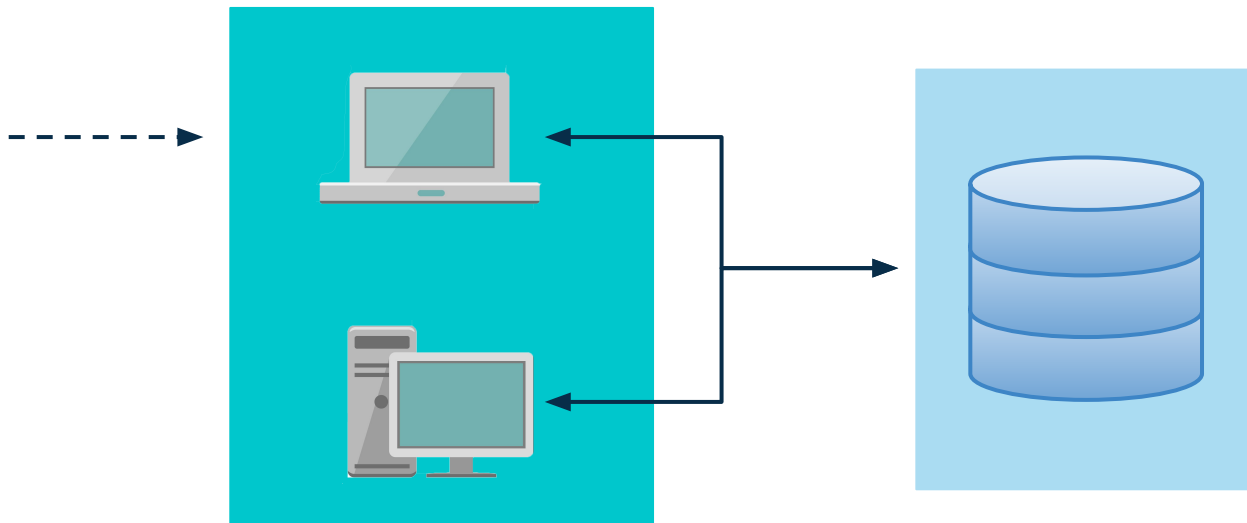
Defining Attack Strategies

Attack option #10: Social engineering

An attacker can ask users for their credentials by pretending to be an administrator.



Fake admin





Questions?





Break
15 mins



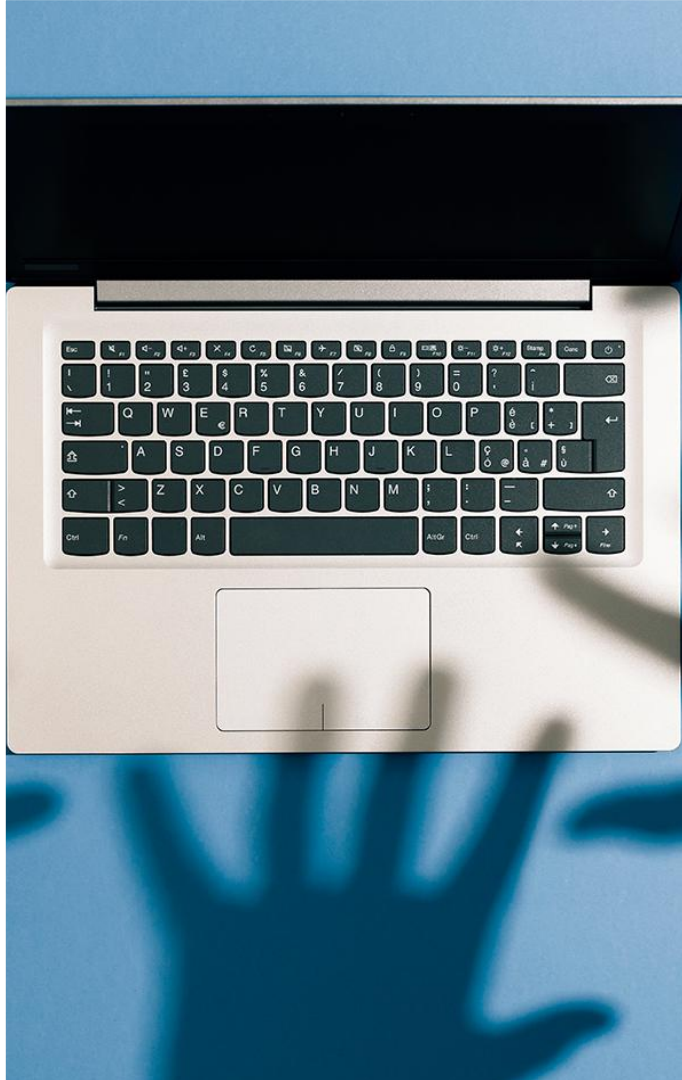
Security Task #3

Defending the Wall

In the same groups, you will now use your list of potential attacks from the previous activity to develop a list of at least 10 strategies to mitigate the website's risk.

As you work through this scenario, consider the following:

Can any mitigation strategies be used to handle multiple threads at once?





Activity:

Defending the Wall

Now that we've assembled a list of potential attacks, your next task is to develop a list of at least 10 strategies to mitigate the website's risk of unauthorized access. Be prepared to share!

Suggested Time:
20 Minutes





Time's up!
Let's review

Risk Mitigation Plan

Potential Defenses

01

Strong password policies

02

Phishing training programs

03

Anti-keylogging software

04

Session management security

05

Encryption

Risk Mitigation Plan

Potential Defenses

06

Multi-factor authentication (MFA)

07

Regular security audits

08

Software and patch management

09

Employee security training

10

Advanced intrusion detection systems



Effective **risk mitigation strategies** can address **multiple** threats at once.



Thank you